

COMPLIANCE MATRIX

Identity & Access Management (IAM)

Control ID	Control Name	Framework Ref.	Implementation Details	Status	Evidence / Notes
IAM-01	Least-privilege access	ISO 27001 A.9.2	Three IAM groups (Admin, Developer, Auditor) with scoped policies; no wildcard resources for Dev/Auditor	Compliant	IAM policy JSON; group membership screenshot
IAM-02	MFA for privileged users	NIST 800-53 IA-5	MFA condition enforced on Admin group via aws:MultiFactorAuthPresent condition key	Compliant	IAM policy condition key screenshot
IAM-03	No root account usage	ISO 27001 A.9.4	Root has no access keys; CloudWatch alarm fires on any root login	Compliant	CloudTrail log + CloudWatch alarm #1
IAM-04	Role-based access control	ISO 27001 A.9.1	Access via IAM groups only; no direct user permissions granted	Compliant	IAM user-group mapping screenshot
IAM-05	Periodic access review	ISO 27001 A.9.5	IAM Access Analyzer recommended; no automated quarterly review yet configured	Partial	Manual review process documented

Network Security

Control ID	Control Name	Framework Ref.	Implementation Details	Status	Evidence / Notes
NET-01	Network segmentation	NIST 800-53 SC-7	VPC with public subnet (web) and private subnet (DB); private subnet has no internet gateway route	Compliant	VPC subnet route table screenshots
NET-02	Minimal inbound rules	ISO 27001 A.13.1	Web SG: ports 443, 80, 22 (admin IP only). DB SG: 3306/5432 from Web SG reference only	Compliant	Security Group rule screenshots
NET-03	VPC Flow Logs	NIST 800-53 AU-12	VPC Flow Logs not yet enabled; all network traffic currently unlogged	Partial	Recommended, not yet active
NET-04	WAF / DDoS protection	NIST 800-53 SC-5	AWS WAF not configured; Shield Standard active automatically by default	Partial	Shield Standard auto-applied; WAF pending

Encryption & Key Management

Control ID	Control Name	Framework Ref.	Implementation Details	Status	Evidence / Notes
ENC-01	Encryption at rest - EBS	NIST 800-53 SC-28	EBS volumes encrypted at creation using AWS KMS Customer Managed Key (CMK)	Compliant	EBS volume encryption status; KMS key ARN
ENC-02	Encryption at rest - S3	ISO 27001 A.10.1	S3 SSE-KMS enforced on all buckets	Compliant	S3 bucket properties; bucket policy
ENC-03	Key rotation	NIST 800-53 SC-12	Automatic annual key rotation enabled on Admin CMK in AWS KMS	Compliant	KMS console key rotation status
ENC-04	Key access least privilege	ISO 27001 A.10.1	KMS key policies restrict usage to designated IAM roles only; no wildcard principals	Compliant	KMS key policy document
ENC-05	Encryption in transit	NIST 800-53 SC-8	HTTPS (443) enforced on web server; all internal comms within VPC boundary	Compliant	Security Group allows 443; SSL certificate

Security Operations & Monitoring

Control ID	Control Name	Framework Ref.	Implementation Details	Status	Evidence / Notes
MON-01	API activity logging	NIST 800-53 AU-2	CloudTrail enabled in all regions; logs stored in SSE-KMS encrypted S3 bucket	Compliant	CloudTrail trail configuration screenshot
MON-02	Root account login alert	NIST 800-53 AC-2	CloudWatch metric filter + SNS alarm on any root account API call or login	Compliant	CloudWatch alarm ARN; SNS topic
MON-03	Unauthorised API call alert	NIST 800-53 SI-4	Metric filter on AccessDenied/UnauthorizedOperation; alarm fires at 5 events in 5 min	Compliant	CloudWatch metric filter pattern
MON-04	Failed login alert	NIST 800-53 AC-7	Metric filter on ConsoleLogin failures; alarm threshold 3 failures in 5 minutes	Compliant	CloudWatch metric filter pattern
MON-05	SIEM / GuardDuty	NIST 800-53 SI-4	GuardDuty not yet enabled; recommended for ML-based anomaly and threat detection	Partial	Recommended as next hardening step

Compliance Summary

Compliant	Partial	Non-compliant
15 / 19	4 / 19	0 / 19